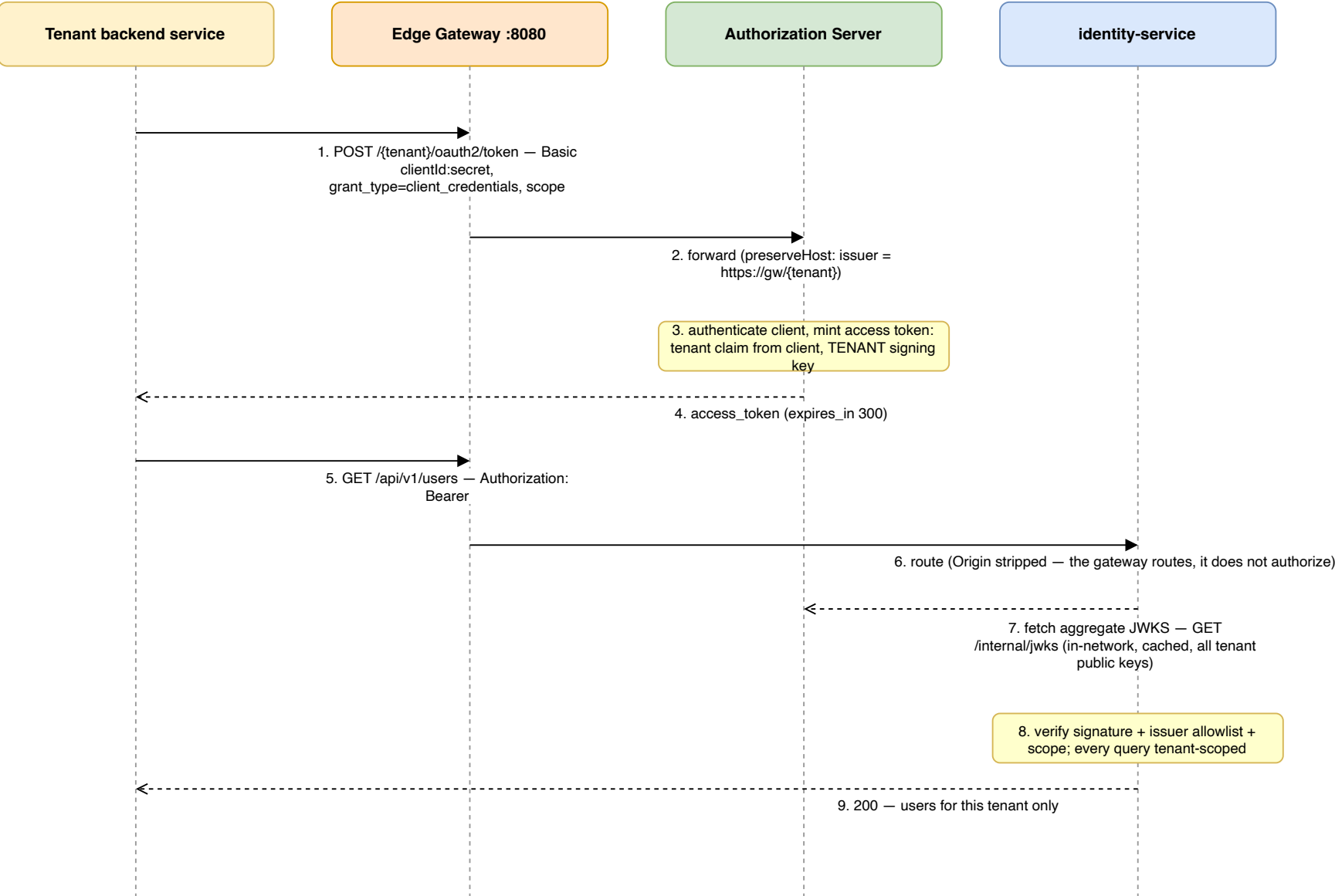


Machine-to-machine (client_credentials) + zero-trust validation at the resource server



Zero-trust: the resource server validates every request itself — signature against the aggregate JWKS (fetched in-network from the AS), issuer against an explicit allowlist (root + gateway per-tenant issuers), and the required scope per endpoint. Cross-tenant access is impossible by construction: repositories only expose tenant-scoped queries keyed by the token's tenant claim.

